ÉQUIPE 20 · TRACK 1 — FINTECH SECURITY : GUARDIANS OF VALUE

Crypto-Secure

Une clé volée ne doit presque rien valoir.

PROTOCOLE RESOLV



~200 000 $

déposés par l'attaquant

→



80 M jetons

mintés avec une clé valide

→



17 min

et le stablecoin perd son ancrage

Aucune cryptographie cassée. **Juste une clé valide.**

LE PROBLÈME

Surveiller autour du contrat ne suffit pas.

Tout est légitime pour le contrat : la signature est bonne



Signature valide

la clé de service est volée

→



Mint

80 M jetons sans dépôt derrière

→



Vente, dépeg

en 17 minutes

→



Alerte…

trop tard : les jetons sont vendus

↑ c'est ici qu'un outil de surveillance classique réagit

⏱️ Un exploit DeFi se joue en **minutes**, plus vite qu'une équipe humaine ne décide.

Notre question : comment faire pour qu'une clé volée ne vaille **presque rien** ?

NOTRE SOLUTION

Trois protections, dans le contrat.

1

Le contrat dérive le montant

La signature autorise « traiter la demande n°X ». Le montant, c'est le contrat qui le lit dans le dépôt on-chain.

2

Perte maximale bornée

Vérifiée par tests d'invariants et fuzzing Foundry, avec la clé de service volée.

3

Pare-feu de contagion

Une balise de risque que les protocoles de prêt lisent pour refuser une garantie suspecte.

👻 Token Ghost

pour l'attaquant qui passe quand même

Transfert → **Jeton d'attente** librement échangeable →

⏱️ 10 min sans anomalie → vrai jeton 1:1

🔥 Fraude confirmée → détruit

Ces dix minutes, c'est **le temps qu'on achète aux défenseurs**.

DÉMO EN DIRECT

La même attaque, rejouée devant vous.

Dashboard → **Démo interactive** · seed 20 · aucune vraie valeur en jeu

⛓ Sur Avalanche Fuji

vraies transactions, vérifiables sur Snowtrace

✗ **Contrat classique** : 1 000 USDC déposés → **1 000 000** jetons acceptés

✓ **Crypto-Secure** : le même mint est **rejeté on-chain**, seuls les 1 000 du dépôt sont servis

🕵 Le pirate discret

il reste sous les plafonds

- Contrat seul : **0** rejet
- Alerte **296 s** après le mint, fenêtre de 10 min
- Retard ciblé : **< 2 %** de l'offre
- 2 humains sur 3 confirment : Ghost suspect **détruit**
- Journal d'audit + rapport DORA pré-rempli

🔁 Et si on se trompe ?

fausse alerte (scénario N3)

- Personne ne confirme
- Le retard **expire seul**
- **0** destruction

CE QU'ON A MESURÉ

Chaque chiffre sort d'une commande du dépôt.

0

perte du protocole avec la clé de service volée

`tests d'invariants Foundry`
`dashboard.demo run A`

296 s

délai de détection, pour une fenêtre Ghost de 10 min

`dashboard.demo run B`
`seed 20`

0 / 864

faux positif sur des tranches de 5 min de trafic normal

`make calibrate, seed 42`
`profil petits transferts`

<2 %

de l'offre touchée par la réponse. **8 %** pour une fausse alerte, qui se résorbe seule

`dashboard.demo run B / N3`
`seeds 7, 20, 42`

Ce qu'on vous dit aussi : profil « gros transferts », **5** faux positifs aux seuils bas, **0** en remontant le seuil · coût permanent : **~3 %** de l'offre immobilisée en Ghost.

Données synthétiques, graines fixes, rejouables depuis le dépôt · détail : `docs/CLAIMS.md`

CONFORMITÉ ET EXPLICABILITÉ

L'IA retarde. Les humains tranchent.

📄 DORA

- Détection et classification
- Journal d'audit horodaté, append-only
- Rapport d'incident pré-rempli selon les rubriques de notification d'incident majeur
- Un brouillon que l'humain relit, pas une déclaration automatique

QUI DÉCIDE QUOI

🤖 **IA et surveillants → retarder**
réversible, ciblé, expire seul

👥 **Humains 2 sur 3 → détruire**
le Ghost suspect, irréversible

🛑 **Humains 3 sur 3 → pause globale**
dernier recours

Pour l'auditeur, chaque décision a : un auteur · une alerte d'origine · un quorum · une heure

POUR QUI, ET QUEL MODÈLE

On fait payer le risque, pas l'usage.

🏦 Émetteurs

de stablecoins et d'actifs tokenisés

📜 Prestataires crypto

soumis à MiCA et DORA

🤝 Protocoles de prêt

qui acceptent ces jetons en garantie

Une commission, à **un seul moment** : quand un Ghost sort de quarantaine et devient du vrai jeton.



Sortie de quarantaine

=

Petit plancher fixe

→ rémunère l'opérateur

+

Supplément indexé sur le ratio de contamination

→ alimente un fonds d'assurance

Transferts et swaps : **gratuits** · rien n'est prélevé sur l'argent saisi et restitué aux victimes

ÉQUIPE, LIMITES, SUITE

@denybs
Contrats · LLM

@Yannis1307
Monitor · Détection

@EnzoFB06
Réponse · Données

@marceaupatu123
Dashboard · Shared · Docs

Ce qu'on ne couvre pas

- Clés d'administration supposées saines
- Une détection plus lente que la fenêtre de 10 min
- La perte est reportée sur les acheteurs de Ghost suspect, pas effacée
- Contrats déployés sur Fuji ; détection mesurée sur trafic synthétique

Suite

- Surveillants branchés en continu sur testnet
- Signatures à seuil (MPC)
- Enclave pour la clé de service

36 heures : une clé volée ne choisit plus le montant. Merci.

ANNEXE A1 · QUESTIONS

Qui perd quand on vend du Ghost suspect ?

Cas 3 de la démo Fuji, en vraies transactions : le vendeur est payé en Ghost, pas en USDC.



Achat

l'acheteur honnête paie 1 000 USDC, **bloqués au coffre**

→



Signalement

le Ghost suspect du vendeur est gelé

→



Gardiens 2 sur 3

Ghost suspect détruit, Ghost de paiement du vendeur brûlé

→



Restitution

1 000 USDC rendus à l'acheteur, coffre à 0

Vendeur : **0 USDC** à la fin · protocole : **rien gardé**

Limite assumée : le Ghost déjà converti avant l'alerte échappe à la destruction.

ANNEXE A2 · QUESTIONS

La balise protège les protocoles de prêt en aval.

Sans balise

76 000

mUSDC de mauvaise créance

Avec balise lue

0

la garantie suspecte est refusée

100 000 Ghost 100 % suspects déposés en garantie, LTV 80 %. Rejeu dashboard (LTV 50 %, un emprunteur légitime en plus) : **21 250 → 0**, et **0** emprunt légitime refusé.

`contracts/test/RiskBeacon.t.sol · test_scenarioC_bad_debt_with_vs_without_beacon · marché de prêt fictif`

ANNEXE A3 · QUESTIONS

Ce que ça coûte, ce qui reste ouvert.

Coûts mesurés

- Ghost immobilisé (fenêtre 10 min) : **3,2 %** médiane, **5,7 %** p95
- Fausse alerte (N3) : **8,1–8,5 %** de l'offre retardée, retour seul, 0 destruction
- Faux positifs, gros transferts : **5** à z = 2, **0** dès z volume = 6
- Ghost reste échangeable pendant l'attente

Limites

- Détection > 10 min : tout est converti (marge bornée par la tranche de 5 min)
- Latence réseau réelle non mesurée
- Trafic synthétique, une graine pour la calibration
- Multisig simulé dans la maquette ; seuils et durées non actés
- Fuzzing = exploration, pas preuve formelle

ANNEXE A4 · QUESTIONS

Couverture NIST CSF 2.0

Govern	L'IA ne fait que retarder ; destruction et pause globale restent des décisions humaines tracées.
Protect	Montant dérivé du dépôt on-chain ; tout transfert passe par un Token Ghost converti 1:1 après une fenêtre sans anomalie.
Detect	Surveillants à règles : mints hors invariant, transferts à volume élevé ET dispersion effondrée.
Respond	Réponse graduée : retard auto-expirant, destruction 2/3, pause globale 3/3 ; balise de risque vers l'aval.
Recover	Transfert suspect annulable tant que son Ghost n'est pas converti ; restitution, journal d'audit, rapport d'incident.